

Introduzione al GDPR

Maggio 2019

Background

- 63%: Persone che hanno perso il controllo sulle modalità in cui i loro dati sono utilizzati
- 85%: Persone preoccupate dell'eventuale passaggio o vendita delle loro informazioni personali da parte delle organizzazioni.



Primi passi del GDPR— ambito e struttura

- **Non elimina completamente il vecchio codice** per la privacy (Dlgs 196/2003), ma lascia in piedi alcune norme precedentemente previste, ne abroga molte, ne sostituisce o integra qualcuna alla luce delle disposizioni del GDPR.
- Legislazione Europea
- **In vigore dal 25 Maggio 2018**

Quali dati vengono raccolti?

- ‘*Dati Personali*’ — Dati relativi all’individuo
- Il regolamento si applica a:
 - L’elaborazione dei dati personali
 - Sia con mezzi **automatizzati** sia **non-automatizzati**.
- Questo comprende:
 - Dati Personali;
 - Dati Sensibili.



Gestione dei Dati Personali

Titolare dei Dati (Data Controller)

Il titolare dei Dati (Data Controller) è il proprietario dei dati e determina il livello di dati personali che è necessario trattenere. (Human Resources, Finance, Customers). Nel GDPR ed in altre leggi sulla privacy, il titolare dei dati (Data Controller) ha una grande responsabilità quando si tratta di proteggere la privacy e i diritti del soggetto che ha fornito i dati, come l'utente di un sito web. Il titolare dei dati (Data Controller) controlla le procedure e gli scopi dell'utilizzo dei dati.

Responsabile del Trattamento dei Dati (Data Processor)

Il Responsabile del Trattamento dei Dati (Data Processor) è il termine dato all'ente che ha la responsabilità di elaborare i dati personali (ad esempio il team di "Managed Service"). Il **Responsabile** indica una persona fisica o giuridica, un'autorità pubblica, un'agenzia o un altro ente che elabora dati personali per conto del **Titolare**. Ai sensi del **GDPR**, il **titolare** e il **responsabile** dei dati hanno molti doveri simili e devono aderire a principi simili.

Step pratici verso la conformità al GDPR

Verifica dei Dati (Data Audit)

Effettuare un controllo dei dati con particolare attenzione ai dati personali

- Capire il contenuto
- Analizzare i dati per la determinazione di scopi legittimi
- Garantire la conformità con il GDPR

Responsabilità (Accountability):

Affidabilità e Competenza aziendale nella gestione dei dati personali

- Analizzare e documentare i processi per la protezione dei dati
- Mantenimento della documentazione
- Minimizzazione dei dati trattati: gestire solo i dati personali necessari allo scopo per cui sono stati richiesti



Scopi legittimi

Le finalità legittime del GDPR per i Dati personali includono l'elaborazione sulla base di:

- Consenso;
- Interessi legittimi del Titolare dei Dati;
- Necessità per l'esecuzione di un contratto;
- Conformità con gli obblighi di legge;
- Protezione degli interessi vitali del soggetto che ha fornito i dati o di un'altra persona fisica;
- Necessità per l'esecuzione di un compito di pubblico interesse.



Scopi legittimi - Consenso

- Il consenso deve essere aggiornato ogni 2 anni o dopo ogni cambiamento dello scopo per cui è stato dato il consenso
- Condivisione dei Dati – Ogni “terza parte” deve avere una nomina.



Scopi legittimi – Dati Sensibili

Le finalità legittime del GDPR riguardo i **dati personali sensibili** includono:

- Consenso esplicito;
- Obblighi relative all'occupazione e alla previdenza sociale;
- Interessi vitali;
- Necessità per intraprendere azioni legali;
- Notevole interesse Pubblico;
- Diversi problemi scientifici o medici.



Trasparenza

Revisione della “Corretta elaborazione delle informazioni” e delle “Politiche sulla Privacy”

- Politica trasparente per i soggetti, riguardante quali dati sono stati raccolti ed elaborati
- Responsabilità del Data Controller di fornire le informazioni richieste
- Le informazioni devono essere concise, accessibili e chiare.

La politica di detenzione dei Dati di Piksel riguarda:

Come distruggiamo i dati; a quale scopo sono trattenuti; dobbiamo trattenerli per reclami futuri e come saranno distrutti.

Dipartimento legale di Piksel - CONTRATTI

- Revisionare le disposizioni sulla condivisione dei dati;
- Controllare la conformità del contratto di protezione dei dati con il GDPR;
- Revisionare i contratti in cui nominiamo il Titolare dei dati e i Responsabili del trattamento;
- Obblighi diretti;
- Mantenere una registrazione scritta delle attività di elaborazione svolte per ciascun Titolare dei Dati;
- Verificare che i nuovi contratti siano conformi al GDPR;



Data Protection Officer

Si occupa delle richieste/violazioni e costituisce un punto di contatto con il Garante della Privacy.

Ruolo:

- Deve essere indipendente
- Deve riportare al massimo livello di management del Titolare/Responsabile;
- Informa e consiglia sugli obblighi di Data Protection;
- Monitora l'implementazione delle politiche di Protezione dei Dati
- Forma il personale;
- Monitora l'implementazione e l'applicazione del regolamento



Data Privacy / Protection Impact Assessment (DPIA)

Un DPIA è richiesto quando esiste un rischio per i diritti e le libertà degli individui all'interno di una attività di elaborazione dei dati.

Ambiti di applicazione

- Elaborazione automatizzata
- Elaborazione su larga scala di speciali categorie di dati
- Monitoraggio sistematico di un'area accessibile al pubblico su larga scala

Miglioramento dei diritti dell'interessato

- Interessato: persona fisica identificata o identificabile, direttamente o indirettamente, con particolare riferimento a un dato personale.
- I diritti da garantire all'interessato sono:
 - Diritto all'Accesso dei Dati
 - Diritto alla Rettifica
 - Diritto alla Limitazione
 - Diritto all'Oblio
 - Diritto alla Portabilità dei Dati



Protocollo di violazione

In quanto azienda abbiamo bisogno di prevenire una potenziale violazione dei dati (Data Breach) e avere misure tecniche e organizzative per garantire un livello di sicurezza adeguato al rischio.

- Obbligatorio
- Notifica al Garante della Privacy in una situazione di violazione dei dati, a meno che sia improbabile che la violazione dei dati personali presenti un rischio per i diritti e le libertà delle persone fisiche
- **Informare il Garante della Privacy entro 72 ore**

Eccezione alla notifica nel caso in cui:

- Esistono misure di protezione tecnologica e organizzativa
- Il titolare dei dati ha preso provvedimenti per eliminare il rischio
- Riportare la violazione comporterebbe uno sforzo eccessivo

Breach protocol—GDPR Multe

Multe

- Fino a 20 milioni di euro e nel caso di una impresa, il 4% del fatturato totale a livello mondiale.
- Ai sensi del GDPR, eventuali danni subiti devono essere risarciti.

Grazie per l'attenzione...

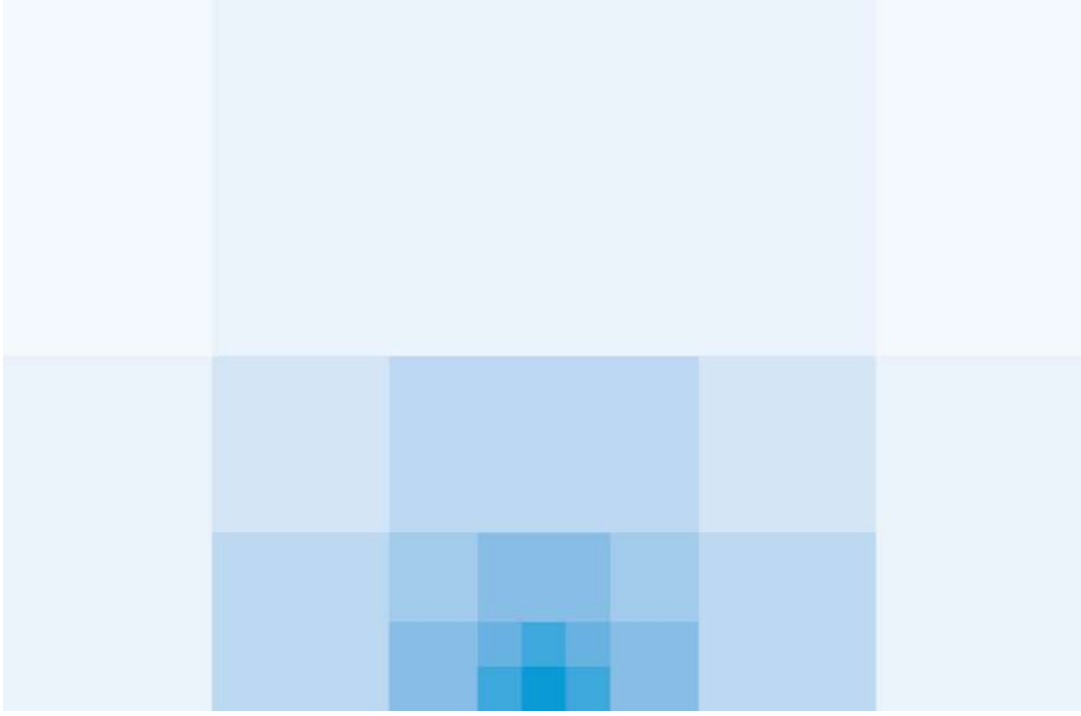
- Per qualsiasi domanda/dubbio relativo alla Protezione dei Dati, contattare il dipartimento “Legal and Compliance”!



Contact us now to find out more about
Piksel and the full range of solutions and
services we provide.

GDPRteam@piksel.com

piksel.com



An Introduction to GDPR- ENGLISH VERSION

May 2019

Background

- 63%: they have lost control over the way their data is used
- 85%: concerned about organisations passing or selling on their information



GDPR first steps—scope and structure

- Partially replaces and Integrates the Italian“ decreto 196 del 2003 “*Codice in materia di protezione dei dati personali* - Testo unico sulla **Privacy**”
- European legislation
- **In force 25 May 2018**

What data is caught?

- ‘*Personal Data*’—data relating to an individual
- The Regulation applies to :
 - The processing of “Personal Data”
 - AND by **automated** and **non-automated** means
- This encompasses:
 - Ordinary Personal Data and
 - Sensitive Personal Data



Handling Personal Data

Data Controller

The Data Controller is the owner of the data and determines the level of personal data that needs to be retained. (HR, Finance, customers)

In GDPR and other privacy laws, the data controller has the most responsibility when it comes to protecting the privacy and rights of the data's subject, such as the user of a website. Simply put, the data controller **controls** the procedures and purpose of data usage.

Data Processor.

The Data Processor is the term given to the body that has responsibility for processing the personal data (e.g. Managed Service team)

Processor means a natural or legal person, public authority, agency or other body which processes personal **data** on behalf of the **controller**. **Under the GDPR** the **controller** and **data processor** have many similar duties and need to adhere to many similar principles.



Practical steps towards GDPR compliance

Data Audit

Carry out a data audit with particular reference to personal data

- * Understand content
- * Analyse data for determination of lawful purposes
- * Ensure compliance with GDPR (rather than DPA)

Accountability:

Document our analysis of lawful purposes of processing activity

- * Evidence for Data Protection
- * Maintain documentation
- * Data minimisation



Lawful purposes

GDPR lawful purposes for **Ordinary Personal Data** include processing on the basis of:

- Consent
- Legitimate Interests of the data controller
- Necessity for the performance of a contract
- Compliance with a legal obligations
- In order to protect the Vital interests of the data subject or of another natural person
- Necessity for performance of a task carried out in the public interest

Lawful purposes—consent

“Consent Guidance Consultation”

- Consent must be refreshed every 2 years or after change of purpose
- Data Sharing—every third party must be named



Lawful purposes—sensitive personal data

GDPR lawful purposes **for sensitive** (now special categories) **personal data** include:

- Explicit Consent
- Employment and Social security obligations
- Vital interests
- Necessary for establishment or defence of legal claims
- Substantial public interest
- Various scientific and medical issues



Transparency

Review of Fair Processing Notices and Privacy Policies

- Open policy with individuals about what data we are collecting and how we are processing it.
- Data Controller's role to provide mandated information
- Information must be concise, accessible, and clear

Piksel's Data Retention Policy covers:

- How we destroy data; for what purpose are they kept; do we need to keep them for future claims; and how they will be destroyed.



Piksel's legal department—CONTRACTS

- Reviewing data sharing arrangements
- Check data protection contract compliance with the GDPR
- Reviewing Contracts where we appoint Data Processors and Data Controllers
- Direct obligations
- Maintain a written record of processing activities carried out for each controller
- Check that new contracts are compliant with the GDPR

The Data Protection Officer

Deals with requests / breaches and acts as the contact point with “Garante della Privacy”

Role:

- * Must be independent
- * Must report to the highest management level of Controller/Processor
- * Informs and advises on DP obligations
- * Monitors the implementation of Data Protection policies
- * Staff training
- * Monitors the implementation and application of Regulation



Data Privacy / Protection Impact Assessment (DPIA)

A DPIA is required where within the processing activity there is a ‘risk to rights and freedoms of individuals’

- Automated processing
- Large scale processing of special categories of data
- Systemic monitoring of publicly accessible area on a large scale
- when the “Garante della Privacy” directs

Enhanced Individual rights

- Ability of individuals to find out about the personal data an organisation holds on them.
 - Subject Access Rights
 - Right to Data Portability
 - Right to be Forgotten

Breach protocol

As a company we need to plan for a potential data breach and have a policy and procedure in place

- Compulsory
- Notification to the “*Garante della Privacy*” in a breach situation unless likely to result in a risk to the rights and freedoms of individuals (eg discrimination, identify theft, or fraud)
- * Must notify “*Garante della Privacy*” **with 72 hours**

Exception to notification to the Data Subject where:

- There is a technological and organisational protection measures
- The Controller has taken action to eliminate the risk
- It would involve disproportionate effort to report the breach



Breach protocol—GDPR Damages and fines

Fines

- Up to 20 million Euro's or in the case of an undertaking 4% of total worldwide annual turnover
- Position under the DPA – Financial loss is required
- Position under the GDPR – Any damages suffered should be compensated



Thanks for listening...

- Any questions/queries that arise in your line of work in relation to Data Protection, please refer to Legal and Compliance!

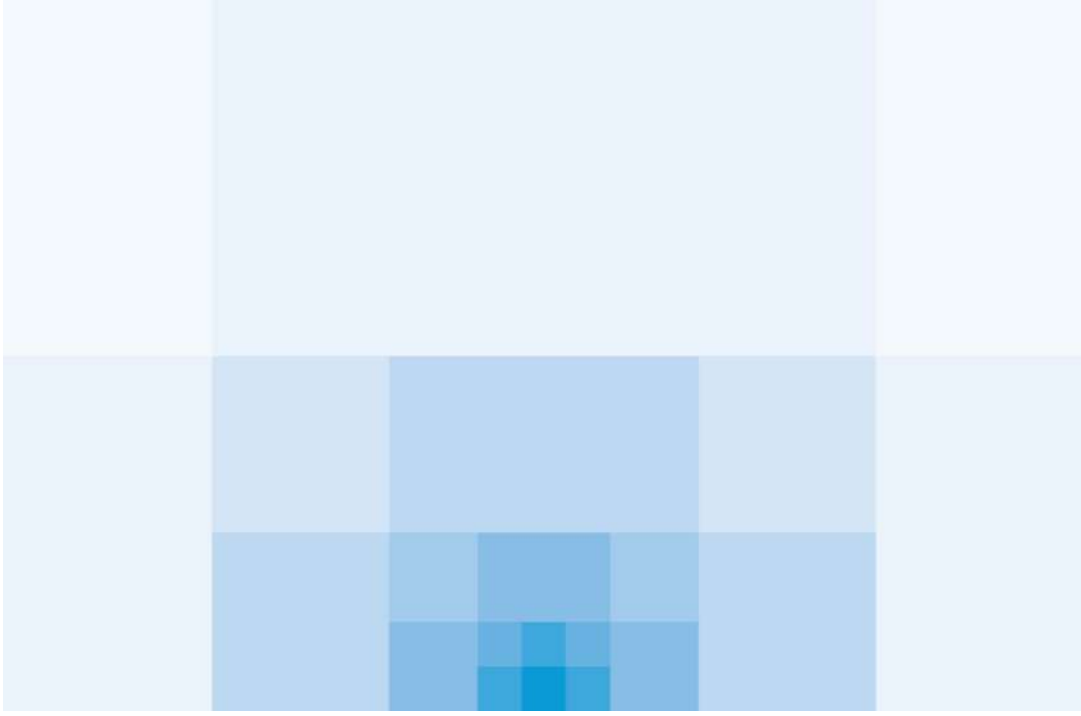




Contact us now to find out more about
Piksel and the full range of solutions and
services we provide.

GDPRteam@piksel.com

piksel.com



Italy - Modulo di conferma della Formazione sul GDPR - GDPR Training Confirmation

- Confermo di aver ricevuto la Presentazione per la Formazione GDPR, come dipendente Piksel.
- Confermo di avere pienamente compreso e accettato quanto riportato nel Training e confermo che lavorerò in accordo con quanto previsto dal GDPR per e per conto del gruppo Piksel.

- I confirm that I have received the GDPR Training Presentation as a Piksel employee.
- I confirm that I have fully understood and accepted the conditions of the training, and will work in accordance with the GDPR legislation while undertaking any and all work for and on behalf of Piksel Group.

Signature/Firma

Date/Data

.....

.....

